

TLS in Practice: Handshakes & Attacks

The Goal of TLS

Authenticate the server (certificates)

Establish encrypted, tamper-proof session

Hide application data + minimize metadata

TLS 1.3 Handshake (Simplified)

Client	Server
----- ClientHello ----->	(key_share, supported groups)
<----+ ServerHello, {Cert}, +Fin --	+ Server's keys (ECDHE)
----- {Finished}, key derived ----->	→ session keys computed
<----+ {Finished} -----	↔ BOTH encrypt now

In TLS 1.3, keys are computed from ephemeral ECDHE values – forward secrecy (compromise of long-term key doesn't decrypt past sessions). 1-RTT full handshake, plus 0-RTT for resumption.

Cipher Suite & TLS Version Attacks

Downgrade attacks – force TLS 1.0/SSL → lobby known ciphers → easier cracking. Modern servers disallow anything below TLS 1.2.

POODLE / BEAST / CRIME – compression+padding attacks on old TLS. Fixed by TLS 1.3 + disabling compression.

Heartbleed (CVE-2014-0160) – bug in OpenSSL's heartbeats leaking server memory (including private keys). Lesson: even perfect crypto fails with buggy *implementation*.

Certificate Validation (Where Attacks Actually Win)

Missing hostname check → any cert accepted → easy MITM

Unchecking cert errors → users wink at the danger

Phishing certs – attacker buys their own DV cert for a lookalike domain (e.g., `paypal.com`)

Detecting TLS Problems (Blue Team)

Use SSLScan/testssl.sh to analyze servers before they join your network

Monitor for self-signed certs on internal hosts

Watch for shadow certs tied to renamed/decommissioned domains

HSTS – force HTTPS and prevent downgrade: `Strict-Transport-Security: max-age=31536000; includeSubDomains`

TLS Observatory Checklist

Min TLS 1.2 (prefer 1.3)

Modern AEAD cipher (AES-GCM / ChaCha)

Valid full chain, good expiry

HSTS enabled

Certificate Transparency logged

No weak ciphers/algorithms in suite

[← Digital Certificates & PKI](#)

Module complete ✓